SYNTHETIC FIXTURE: SAFESTRATA INFORMATION SECURITY AND ACCESS CONTROL POLICY 2026

Document ID: POL-SEC-2026-V4 | Effective Date: 2026-02-15 | Classification: Confidential (Analyst, Compliance Manager, Auditor)

1. ACCESS CONTROL AND LEAST PRIVILEGE PRINCIPLES

Access to SafeStrata core compliance repositories, vector stores, and administrative dashboards must strictly adhere to the Principle of Least Privilege and Role-Based Access Control (RBAC). Default access for newly created accounts is Viewer. Escalation to Analyst, Compliance Manager, or Auditor requires written business justification and approvals from the Chief Information Security Officer (CISO).

2. PASSWORD COMPLEXITY AND LIFECYCLE REQUIREMENTS

All SafeStrata domain and system passwords must satisfy the following baseline standards:

- Minimum length of fourteen (14) alphanumeric characters.
- Must contain at least one uppercase letter (A-Z), one lowercase letter (a-z), one numeric digit (0-9), and at least one approved special character (!@#$%^&*).
- Passwords must be rotated every ninety (90) calendar days.
- The previous twelve (12) passwords cannot be reused.
- Account lockout is triggered automatically upon five (5) consecutive failed authentication attempts. Lockout duration is thirty (30) minutes unless manually unlocked by an authorized administrator.

3. MULTI-FACTOR AUTHENTICATION (MFA)

Multi-Factor Authentication via hardware security keys (FIDO2/WebAuthn) or time-based one-time password (TOTP) apps is mandatory for all access. SMS-based OTP is prohibited for administrative and analyst access tiers due to SIM-swapping vulnerabilities.

4. SESSION TIMEOUT AND SCREEN LOCK

All workstations and browser sessions connected to SafeStrata services must enforce an idle timeout of fifteen (15) minutes. After fifteen minutes of inactivity, the session must automatically lock, requiring re-authentication.

5. REMOVABLE MEDIA AND USB RESTRICTION

The use of external USB storage media, flash drives, and portable hard drives is blocked by default across all endpoint devices via Endpoint Detection and Response (EDR) policy. Any temporary exception requires formal CISO sign-off and is logged in the compliance audit

repository.